



Répartition des Tâches : Serveur Web Sécurisé (Projet Bi-personne)

Les Rôles du Projet



Elod A : Lead Backend & Sécurité Applicative

- **Focus** : Le cœur de l'application (logique métier) et la sécurité interne (authentification, autorisation).
- **Compétences requises** : Maîtrise de Java et du framework Spring Boot.



Athos B : Lead Système & Intégration

- **Focus** : L'infrastructure d'exposition (réseau, frontal, sécurité périmétrique), l'observabilité et la documentation.
- **Compétences requises** : Connaissances en réseau (HTTP/TLS), administration système (Reverse Proxy), et rigueur documentaire.

Phase 1 : Fondations et Conception (Semaine 1)

Jalon Cible : Jalon A

Travail Partagé

L'alignement sur les choix technologiques et la vision architecturale est essentiel.

- **Apprentissage (Théorie)** : Les deux personnes doivent comprendre la **séparation des responsabilités** (Frontal vs. Application) et les concepts de **HTTPS partout, PFS et HSTS**.
- **Tâche** : Finaliser la structure du **Manuel de référence** et valider l'environnement de travail.

Responsabilités Spécifiques

- **Elod A (Backend) :**
 - **Apprendre** : Les bases de la structure d'un projet Spring Boot (contrôleur, service, repository).
 - **Tâche** : Initialiser le projet Spring Boot et le répertoire de code.
- **Athos B (Système) :**
 - **Apprendre** : Les rôles et les choix du Reverse Proxy.
 - **Tâche** : Rédiger et finaliser les **Schémas d'architecture** (Vue logique et Flux d'authentification), ainsi que la première version du **Plan de tests** (cas de base).

Phase 2 : Développement du MVP (Semaines 2 & 3)

Jalon Cible : Jalon B (MVP prêt)

Cette phase est principalement portée par la Personne A, la Personne B se concentrant sur la préparation du système et de la documentation.

Responsabilités Spécifiques

- **Elod A (Backend) :**
 - **Apprendre** : Le fonctionnement interne des **Jetons JWT** (Header, Payload, Signature) et la configuration de **Spring Security** pour le support JWT. Maîtriser le **hachage des mots de passe** (bcrypt ou Argon2).
 - **Tâches** :
 1. Implémenter le modèle de données **Utilisateur** et la fonction de hachage.
 2. Développer la **Ressource publique** (**/status** ou **/accueil**).
 3. Implémenter le **Parcours d'authentification** (Login) et la fonction **d'émission du JWT signé**.
 4. Mettre en place le filtre de sécurité Spring pour la **validation du JWT** (signature et expiration) sur une ressource protégée.
 - **Livrable** : API Java fonctionnelle sur une connexion locale.
- **Athos B (Système) :**

- **Apprendre** : Les principes de base de la configuration d'un Reverse Proxy (sans la sécurité avancée pour l'instant).
- **Tâches** :
 1. Mettre en place l'environnement pour le **Reverse Proxy**.
 2. Préparer les modèles de configuration du frontal pour relayer les requêtes vers l'application de la Personne A.
 3. Affiner les scénarios de tests liés à l'authentification (jetons invalides).

Phase 3 : Durcissement et Intégration (Semaines 4 & 5)

Jalon Cible : Jalon C

C'est la phase d'intégration où les deux rôles travaillent le plus en collaboration et en parallèle.

Responsabilités Spécifiques

- **Elod A (Backend)** :
 - **Apprendre** : L'implémentation du **moindre privilège** et des expressions de sécurité Spring pour l'autorisation fine.
 - **Tâches** :
 1. Implémenter la gestion des **Autorisations par rôles** (ex: `ROLE_USER`, `ROLE_ADMIN`) sur les ressources protégées.
 2. Développer les **Sondes de santé** (`liveness/readiness`) via Spring Boot Actuator.
 3. Assurer la **Validation d'entrée** (schéma) et la **Gestion d'erreurs propre** de l'application.
- **Athos B (Système)** :
 - **Apprendre** : Les définitions et la configuration des **En-têtes de sécurité HTTP** (CSP, HSTS, X-Frame-Options, etc.).
 - **Tâches** :
 1. Configurer le Reverse Proxy pour la **Terminaison TLS/HTTPS** complète et les redirections.

2. Intégrer les **En-têtes de sécurité HTTP** au niveau du frontal.
3. Mettre en place la **Journalisation structurée** du frontal et s'assurer que les logs de la Personne A sont collectés (corrélation, statut HTTP).
4. Tester l'intégration complète (Reverse Proxy vers Backend).

Phase 4 : Tests, Observabilité et Finalisation (Semaines 6 & 7)

Date limite : 23 décembre | Jalon Cible : Jalon D

La Personne B mène cette phase axée sur la qualité et les livrables documentaires, avec le support de la Personne A pour les corrections de bugs.

Responsabilités Spécifiques

- **Elod A (Backend) :**
 - **Apprendre** : Les bonnes pratiques d'**hygiène des dépendances** (versions à jour) et la **traçabilité des configurations** (secrets externalisés).
 - **Tâches** :
 1. Mettre à jour les dépendances et s'assurer qu'aucune fuite d'information ne se produit (ex. secrets dans les logs).
 2. Corriger les anomalies remontées par la Personne B suite aux tests de sécurité.
- **Athos B (Système) :**
 - **Apprendre** : La méthodologie de test de sécurité (scénarios d'accès sans jeton, jeton expiré, etc.) et la rédaction de la synthèse.
 - **Tâches** :
 1. Exécuter l'intégralité du **Plan de tests**, en insistant sur les scénarios de sécurité (Tests de jeton invalide/expiré/rôle insuffisant).
 2. Finaliser la **Documentation utilisateur/lecteur** (parcours d'authentification).
 3. Rédiger la **Synthèse** du projet (limites, axes d'amélioration, perspectives techniques : OAuth2/SSO, CI/CD, HA) .

4. Mettre à jour les **Schémas** et le **Manuel de référence** avec les justifications finales.

1. Les Défis Majeurs |

A. La Courbe d'Apprentissage (Java & Spring Boot)

- **Java** : Même avec de bonnes bases en développement, la transition vers Java (syntaxe, typage fort, concepts orientés objet) demandera au moins la première semaine pour être à l'aise.
- **Spring Boot & Spring Security** : C'est le plus gros obstacle. Spring Security est une bibliothèque puissante, mais sa configuration est complexe et demande du temps pour maîtriser la chaîne des filtres (filtre JWT, gestion des rôles, etc.). Un simple changement peut entraîner des heures de débogage.

B. La Complexité de l'Intégration (Système & Sécurité)

- **Intégration B to B (Backend to Backend)** : Intégrer votre application Java derrière un Reverse Proxy (Nginx ou Traefik) pour la terminaison HTTPS et l'application des en-têtes (Semaines 4-5) nécessite une bonne compréhension du réseau et des outils système, ce qui est le focus de la Personne B.
- **Exigence de Qualité Sécuritaire** : Le projet exige une *sécurité par défaut* et le respect de politiques strictes (signature asymétrique, HSTS, CSP, etc.). Pour une première expérience, atteindre ce niveau de durcissement sans faille est très exigeant.

2. Verdict de Faisabilité |

Niveau de Risque	Condition de Réussite
Élevé (Temps)	Vous devez vous en tenir strictement au Modèle Fonctionnel Minimal (MVP) [cite: 100]. Oubliez les extensions possibles (rafraîchissement de jeton, CI/CD avancé, etc.) pour vous concentrer sur les jalons B et C.

Critique (Compétence)	L'apprentissage de Spring Security (Personne A) et de la configuration TLS/Reverse Proxy (Personne B) doit être votre priorité absolue dès le début de la Semaine 1, en parallèle des bases Java.
Moyen (Test)	Vous devez utiliser le Client API pour tester de manière chirurgicale. Ne pas perdre de temps à faire des tests manuels ou à développer une interface graphique (elle est exclue de toute façon)[cite: 19].

3. Stratégies de Mitigation pour Réussir |

A. Action Immédiate (Dès la Semaine 1)

- **Ne pas réinventer la roue pour Spring Security** : Étant donné le temps limité, cherchez immédiatement des **exemples de starter-project ou des tutoriels très récents** (Java 21/Spring Boot 3) qui mettent déjà en place un filtre de sécurité pour le JWT. Votre travail doit se concentrer sur la compréhension et la **personnalisation** de cette architecture de référence, plutôt que sur sa création à partir de zéro.
- **La Personne B doit s'attaquer au Reverse Proxy immédiatement** : La Personne B peut commencer à monter et configurer l'environnement Reverse Proxy (HTTPS, base Nginx/Traefik) en parallèle de la Personne A, sans attendre la fin du MVP, car c'est un domaine totalement nouveau.

B. Focus sur l'Apprentissage Ciblé

- **Personne A (Backend)** : Concentrez-vous à 90 % sur les aspects sécurité et architecture de Spring Boot (Spring Security, Actuator, injection de dépendances). Les bases Java s'acquerront par la pratique.
- **Personne B (Système)** : Concentrez-vous à 90 % sur la configuration des outils système (Reverse Proxy) et les normes de sécurité (l'impact des en-têtes de sécurité sur le navigateur, le fonctionnement du HSTS).